S06 LAB REPORT

Network Scanning and Vulnerability Assessment

Kali Linux | Metasploitable 2 | Nmap

Zahid Ullah

Cohort 02-Weekend-ISB

Repository path: https://github.com/hckr-zahid/pseb-deploy-bootcamp/tree/main/s06-scanning

Report detail	Value
Attacker machine	Kali Linux
Target machine	Metasploitable 2
Kali IP address	192.168.199.128
Target IP address	192.168.199.129
Scanner	Nmap 7.99
Working directory	~/s06-scanning
Scope	Intentionally vulnerable target in the isolated virtual lab

1. Introduction and Objectives

This lab involved scanning and assessing a Metasploitable 2 virtual machine from Kali Linux. The objectives were to confirm connectivity, identify open ports and running services, investigate security weaknesses, and document findings with supporting evidence. Testing was performed against the intentionally vulnerable lab target.

2. Lab Environment

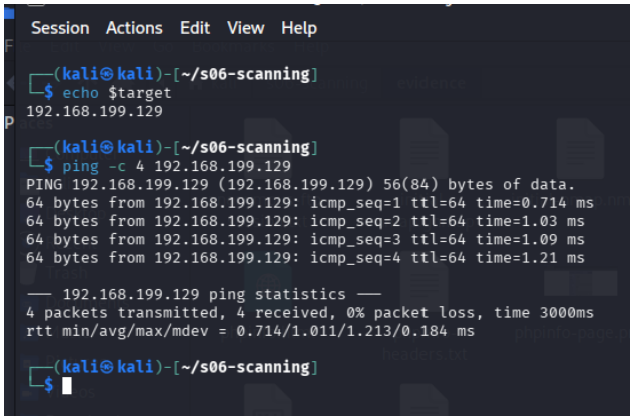
Component	Details
Attacker	Kali Linux
Target	Metasploitable 2
Kali IP	192.168.199.128
Target IP	192.168.199.129
Scanner	Nmap 7.99
Network	Virtual lab network

3. Host Connectivity

The target's reachability was checked from Kali Linux.

```
ping -c 4 192.168.199.129
```

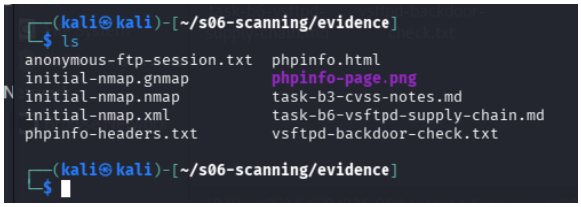
Observed result: 4 packets transmitted, 4 received, and 0% packet loss.



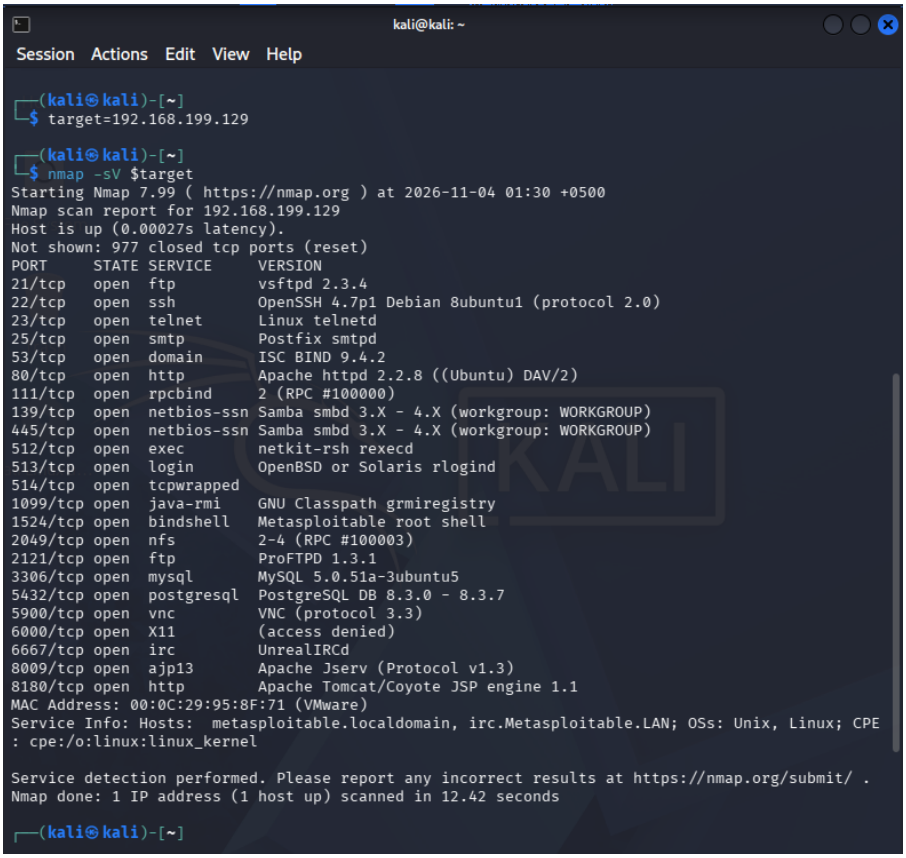
4. Initial Nmap Scan and Service Enumeration

A default-script and service-version scan was run and saved in Nmap's three output formats.

```
cd ~/s06-scanning
sudo nmap -sC -sV -oA evidence/initial-nmap 192.168.199.129
```



The scan identified multiple exposed services. Notable results included FTP/TCP 21 (vsftpd 2.3.4), SSH/TCP 22, Telnet/TCP 23, HTTP/TCP 80 (Apache 2.2.8), SMB/TCP 139 and 445, MySQL/TCP 3306, PostgreSQL/TCP 5432, and other services.



5. Task A: Vulnerability Findings

5.1 Finding 01 : vsftpd 2.3.4 Backdoor (CVE-2011-2523)

Attribute	Assessment
Service / port	FTP / TCP 21
Detected version	vsftpd 2.3.4
Severity assessment	Critical
Issue	Backdoor command execution

The initial scan identified vsftpd 2.3.4. I checked the service using the Nmap ftp-vsftpd-backdoor script.

```
nmap -p 21 --script ftp-vsftpd-backdoor \
-oN evidence/vsftpd-backdoor-check.txt \
192.168.199.129
```

Nmap reported VULNERABLE (Exploitable), identified CVE-2011-2523, and showed the result of the id command:

```
uid=0(root) gid=0(root)
```

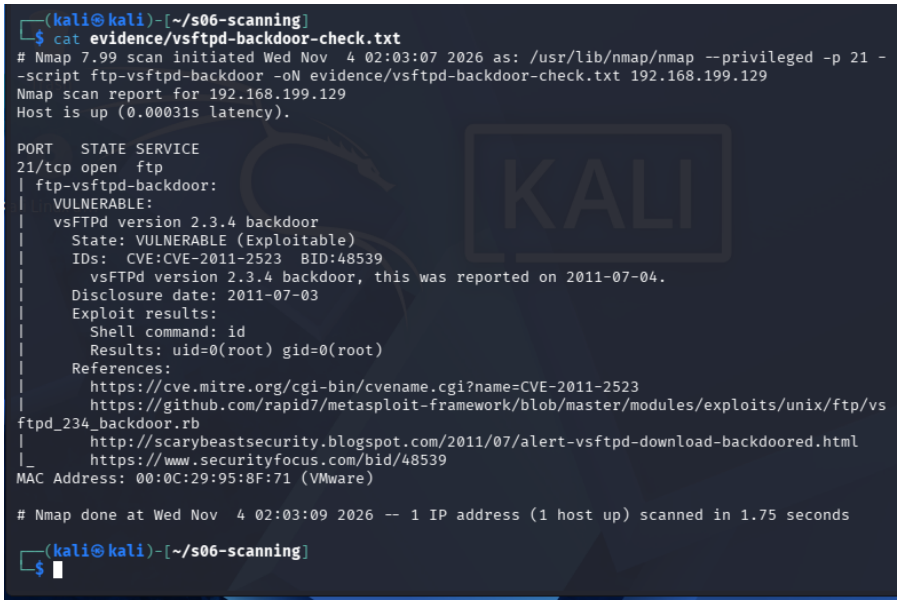
This demonstrates root-level command execution on the Metasploitable 2 target through the backdoor check.

Potential impact

On a real system, unauthenticated remote command execution with root privileges could expose sensitive information, permit unauthorized changes, disrupt services, and compromise the host.

Recommendation

Remove the affected software, install a trusted and supported version, verify software signatures or checksums, and restrict FTP exposure where it is not required.



5.2 Finding 02 — PHP Information Disclosure

Attribute	Assessment
Service / port	HTTP / TCP 80
Page	/phpinfo.php
Severity assessment	Medium (lab assessment)
Issue	Public PHP configuration information

I requested the page's HTTP headers.

```
curl -I http://192.168.199.129/phpinfo.php
```

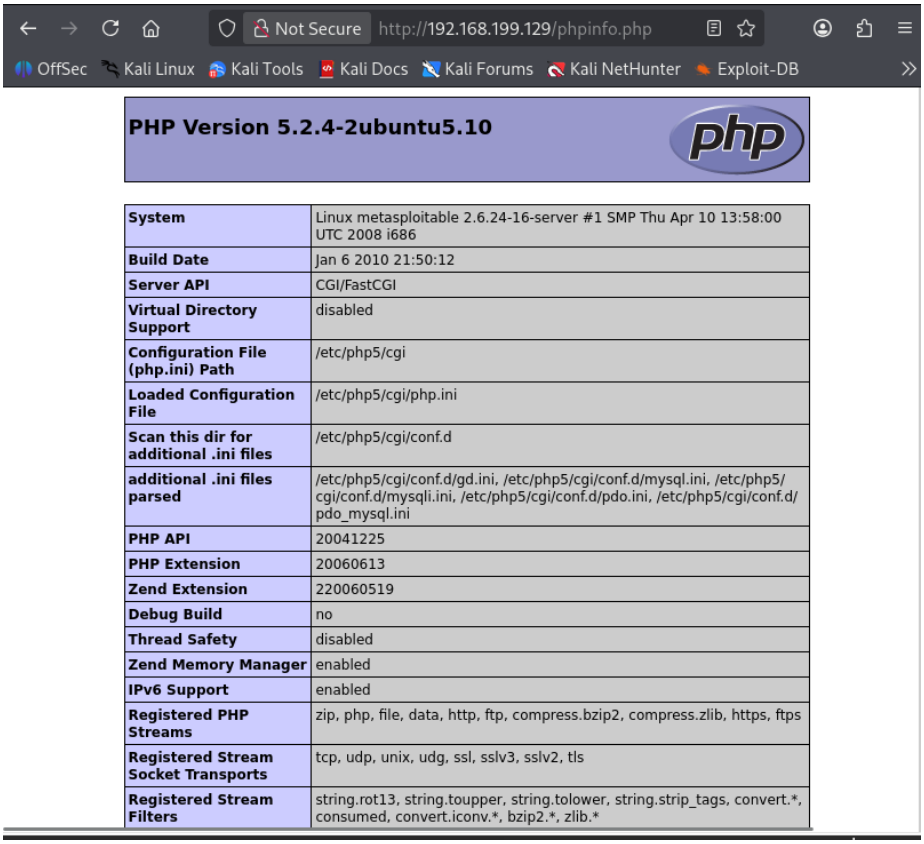
The server returned HTTP 200 OK. The headers identified Apache 2.2.8 and PHP 5.2.4. The saved PHP information page exposed additional environment and configuration details, including operating-system and configuration-path information.

Potential impact

Exposed versions and configuration details can help an attacker fingerprint the server and plan further attacks. This test confirms information disclosure; it does not by itself demonstrate compromise of the web server.

Recommendation

Remove phpinfo.php from public web directories or restrict it to authorized administrators. Avoid exposing detailed configuration information to unauthenticated visitors.



5.3 Finding 03 — Anonymous FTP Access

Attribute	Assessment
Service / port	FTP / TCP 21
Observed behaviour	Anonymous login accepted
Severity assessment	Medium; depends on accessible data and permissions
Issue	Anonymous FTP access enabled

I connected to the FTP service. A login attempt using kali failed; a subsequent login using anonymous succeeded with the server response 230 Login successful.

```
ftp 192.168.199.129
Name: anonymous
Password: [press Enter if prompted]
ftp> pwd
ftp> ls
```

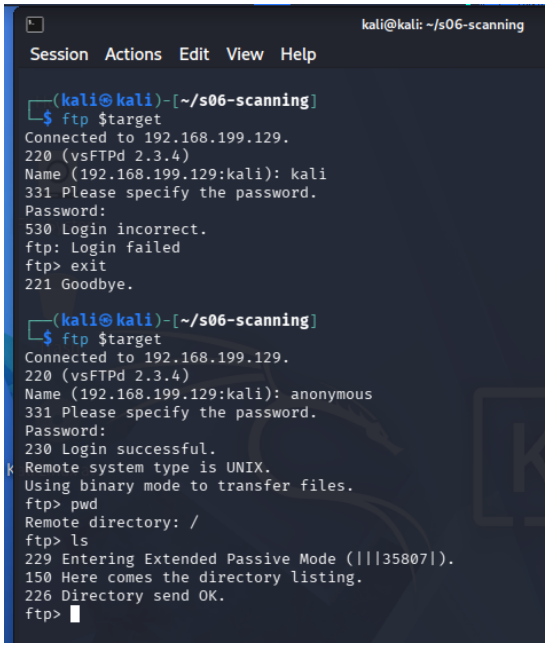
The working directory was reported as /. The directory listing operation completed successfully, but no filenames were displayed. Therefore, the test confirms anonymous authentication and a successful listing response; it does not establish that files were exposed.

Potential impact

Anonymous access can expose files if they are present in the accessible directory and readable by anonymous users. No filenames were shown in this test.

Recommendation

Disable anonymous FTP unless explicitly required. If required, restrict the account to a dedicated directory and apply least-privilege permissions.



6. Task B3: CVSS Metric Decoding for CVE-2011-2523

The following explanations decode the metric values into plain English.

CVSS 3.1 vector

```
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
```

Metric	Value	My interpretation
Attack Vector (AV)	N	The attacker can reach the vulnerable FTP service over a network.
Attack Complexity (AC)	L	The attack does not require unusual conditions or complicated preparation.
Privileges Required (PR)	N	The attacker does not need an existing account or prior privileges.
User Interaction (UI)	N	No action by another user is needed.
Scope (S)	U	The consequences remain within the security authority of the affected system.
Confidentiality (C)	H	Successful exploitation can expose sensitive information.
Integrity (I)	H	Successful exploitation can allow unauthorized modification of data.
Availability (A)	H	Successful exploitation can interrupt services or make the system unavailable.

CVSS 2.0 vector

```
AV:N/AC:L/Au:N/C:C/I:C/A:C
```

Metric	Value	My interpretation
Access Vector (AV)	N	The attack can be launched over a network.
Access Complexity (AC)	L	The attack requires relatively few special conditions.
Authentication (Au)	N	No authentication is required before attempting the attack.
Confidentiality (C)	C	The attack can expose all information protected by the affected system.

Integrity (I)	C	The attack can allow extensive unauthorized changes.
Availability (A)	C	The attack can cause complete loss of service availability.

Assessment

The vectors describe a remotely reachable vulnerability that does not require prior authentication. The potential consequences affect confidentiality, integrity, and availability. In the practical test, Nmap's backdoor script ran id and returned uid=0(root) gid=0(root), demonstrating root-level command execution on the target.

The published base scores are 9.8 under CVSS 3.1 and 10.0 under CVSS 2.0. The versions use different metric systems, so their scores should not be treated as directly interchangeable.

Supporting notes: evidence/task-b3-cvss-notes.md

References:

- NIST NVD, CVE-2011-2523: https://nvd.nist.gov/vuln/detail/CVE-2011-2523
- FIRST, CVSS v3.1 Specification: https://www.first.org/cvss/v3.1/specification-document
- FIRST, CVSS v2 Guide: https://www.first.org/cvss/v2/guide

7. Task B6: vsftpd Supply-Chain Compromise

What happened?

In 2011, the official vsftpd download site was compromised and the vsftpd-2.3.4.tar.gz source archive was replaced with a modified version containing a malicious backdoor. Historical reporting described the compromised archive as available for approximately three days around the end of June and beginning of July 2011. This was a supply-chain attack because the software distribution process was tampered with.

The backdoor was designed to activate when an FTP login username contained the characters :). After activation, it opened a shell on TCP port 6200, potentially allowing command execution on the affected machine. The issue is associated with CVE-2011-2523.

How was it discovered?

Contemporary reporting credited Mathias Kresin with noticing the suspicious archive. Chris Evans, the vsftpd author, investigated and warned users that the download had been compromised. A failed detached GPG signature verification was an important indication that the archive could not be authenticated as an unmodified release.

Why is it relevant today?

The incident demonstrates that trusting a software name or download location is not enough. If an attacker compromises a project's distribution site, users who download the tampered package may install malicious code. Modern systems depend on external packages, repositories, build systems and distribution services, so supply-chain risks remain relevant.

Risk-reduction measures include verifying digital signatures and checksums, obtaining software from trusted sources, keeping software updated, monitoring unexpected network services, and maintaining an inventory of installed software.

Supporting notes: evidence/task-b6-vsftpd-supply-chain.md

References:

- Chris Evans, Alert: vsftpd download backdoored (July 2011): https://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
- The Register, Popular FTP package download tarball poisoned (July 5, 2011): https://www.theregister.com/security/2011/07/05/popular_ftp_package_download_tarball_poisoned/
- NIST NVD, CVE-2011-2523: https://nvd.nist.gov/vuln/detail/CVE-2011-2523

8. Conclusion

This lab demonstrated how host connectivity checks, port scanning, service enumeration and focused vulnerability checks can identify weaknesses in a target environment. Three Task A findings were investigated: the vsftpd 2.3.4 backdoor, publicly accessible PHP information, and anonymous FTP access. Task B3 decoded CVSS metrics, while Task B6 examined the historical vsftpd supply-chain compromise. The exercises reinforce the importance of reducing exposed services, restricting anonymous access, protecting configuration information, and verifying software authenticity.

9. Evidence Inventory

File	Purpose
initial-nmap.nmap / .xml / .gnmap	Initial scan output in three formats
vsftpd-backdoor-check.txt	Nmap check for CVE-2011-2523
phpinfo-headers.txt	HTTP response headers
phpinfo.html	Saved PHP information page
phpinfo-page.png	PHP information screenshot
anonymous-ftp-session.txt	Recorded anonymous FTP session
task-b3-cvss-notes.md	CVSS decoding notes
task-b6-vsftpd-supply-chain.md	Supply-chain research notes